# Table of Contents

# Cisco Secure Workload — Sarbanes-Oxley (SOX) IT General Controls

## Reference Design | Internal Audit, SOX PMO & IT Compliance Teams

**Version:** 1.0 (draft v1 — see scoping note below) **Use Case:** Fresh Install, Hybrid Environment (On-Prem + Cloud)

---

## Scoping note — read this first

**SOX is a statute, not a control catalogue.** The Sarbanes-Oxley Act of 2002 requires management to assess internal control over financial reporting (**Section 404(a)**) and, for accelerated filers, requires the external auditor to attest to it (**Section 404(b)**). Neither the Act nor the SEC publishes a list of controls to implement. Companies satisfy SOX by selecting frameworks — **COSO 2013** for the entity-level and **COBIT 2019** for IT general controls — and by designing controls that support the assertions in their financial statements.

This reference design therefore maps CSW to the **four conventional ITGC domains** used by virtually every SOX programme and external audit firm, and cross-references **COBIT 2019** objectives and **PCAOB AS 2201** requirements. It deliberately does **not** invent SOX control identifiers.

The honest summary of CSW's contribution:

| ITGC domain | CSW contribution |
|---|---|
| **Access to Programs and Data** | Substantial — for the **network-path** portion of logical access |
| **Computer Operations** | Moderate — monitoring, availability signals, incident reconstruction |
| **Program Changes** | Limited — technical drift detection, not change authorisation |
| **Program Development** | None |

CSW does not address user entitlement review, segregation of duties inside the financial application, or change-management workflow. Those remain with IAM, PAM, the application, and ITSM. Read Section 10 before writing any control narrative.

---

## Reader's Guide

**Who this is for.** SOX programme managers and internal audit teams scoping IT general controls over financially-relevant systems; IT compliance teams preparing evidence for 404(a) management testing or 404(b) external audit; and security architects who need their segmentation programme to produce artefacts the SOX testers will accept.

**Questions this reference design helps you answer:**

- *Which of my workloads are genuinely in the SOX boundary, and can I defend that boundary to an external auditor with something better than a spreadsheet?*
- *How do I evidence the flow of transactions through the financial reporting system, as PCAOB AS 2201 expects, using a live technical data-flow rather than an aged architecture diagram?*
- *How do I demonstrate **operating** effectiveness of a network access control across the full fiscal period, not just design effectiveness on the walkthrough date?*
- *How do I keep CSW exports admissible as Information Produced by the Entity (IPE), so a tester can rely on them without re-performing the query?*
- *Which ITGC control objectives can carry CSW evidence, and which must I leave entirely to IAM, ITSM, and the application?*
- *Can continuous CSW evidence support a benchmarking or roll-forward strategy and reduce year-end testing effort?*

**What you'll need.** The current SOX scoping memo (significant accounts, in-scope business cycles, and the financially-relevant application list), the infrastructure supporting those applications, your fiscal calendar including quarter-end and year-end close windows, and either CSW already deployed or documented scope decisions for sensor and connector coverage.

**Where to start.** Sections 1–4 if you are defining the SOX boundary; 5–7 if you are baselining transaction flows and designing policy; 8–11 if you are collecting evidence for a testing cycle or an external audit request.

---

## CSW primer — if you are new to Cisco Secure Workload

Cisco Secure Workload (CSW) is a **workload protection platform**. A lightweight **agent** on each server/VM/container observes processes and network flows; **cloud connectors** add AWS/Azure/GCP inventory where agents are not deployed.

| CSW term | Meaning | Why compliance teams care |
|---|---|---|
| **Scope** | Logical boundary (CDE, PHI zone, CUI enclave) | Defines the systems you must prove are isolated |
| **Label / filter** | Tag or query assigning workloads to scopes | Automates scope membership — reduces drift |

| CSW term | Meaning | Why compliance teams care |
|---|---|---|
| **ADM** | Application Dependency Mapping from observed traffic | **Live** network/data-flow diagram for assessors |
| **Workspace** | Policy container for one scope or application | Where allow/deny rules are authored |
| **Monitor → Simulation → Enforce** | Safe rollout sequence | Simulation = change-board evidence before blocking traffic |
| **Denied Connections** | Log of flows blocked by policy | Primary proof that enforcement **operates** |

**Console areas:** Investigate (inventory, flows, vulns) · Defend/Segmentation (policy) · Manage (agents) · Platform (connectors) · Administration (audit log)

**Read next:** Compliance evidence playbook (full step-by-step) · About CSW (platform intro)

---

## Universal evidence workflow

Execute these phases for **this framework's** compliance boundary. Map exports to control objectives in the **Reporting & Evidence** section below.

| Phase | Goal | Key CSW actions | Typical duration |
|---|---|---|---|
| **1 — Coverage** | Every in-scope workload in CSW | Install agents/connectors; apply SOX labels; create scope | Days 1–10 |
| **2 — Baseline** | Machine-generated flow map | Run ADM across a **full close cycle**; export clusters; app-owner signoff | Days 11–45 |
| **3 — Policy** | Designed isolation before enforce | Build workspace; Simulation mode; fix false positives | Days 46–70 |
| **4 — Operate** | Continuous proof across the fiscal period | Enforce; quarterly export pack; ADM refresh every 90 days | Ongoing |

**Note the longer Phase 2.** SOX is the one framework in this library where a two-week baseline is actively insufficient. See Section 5.1.

### Phase 1 checklist (coverage)

- ☐ SOX-relevant host list reconciled to CSW Inventory (100% or documented exceptions)
- ☐ Labels applied: `sox_scope`, `sox_cycle`, `itgc_domain`, `financial_app`
- ☐ CSW scope created matching the SOX boundary from the scoping memo
- ☐ Coverage gaps logged in the deficiency tracker, not just an IT backlog
- ☐ **Export:** inventory CSV + agent status screenshot, both timestamped

### Phase 2 checklist (baseline)

- ☐ ADM running on the SOX scope across **at least one full month-end close**, ideally a quarter-end
- ☐ Batch, interface, and file-transfer flows captured and attributed to a business cycle
- ☐ Unexpected flows documented (undeclared interfaces, vendor egress, scope creep)
- ☐ Application and process owners signed the cluster-to-application mapping
- ☐ **Export:** ADM diagram + flow samples with process context

### Phase 3 checklist (policy)

- ☐ Default-deny posture defined for the financial reporting core
- ☐ ADM-imported rules refined; Simulation run across a close window
- ☐ Change tickets raised for every false-positive fix; exception register updated
- ☐ **Export:** policy export + simulation report, linked to change record IDs

### Phase 4 checklist (operate)

- ☐ Enforcement enabled; negative test recorded in Denied Connections
- ☐ Quarterly pack: inventory, policy, denies, vulns, audit log (see playbook)
- ☐ IPE integrity controls applied to every export (see Section 11.2)
- ☐ SIEM integration verified (sample events)
- ☐ **Export:** enforcement screenshot + quarterly binder with hash manifest

### What CSW evidence does not replace

User access reviews and entitlement recertification, segregation of duties within the financial application, change authorisation workflow, SDLC and program development controls, backup and recovery testing, management review controls, entity-level COSO controls, and external auditor attestation all require separate programmes. CSW addresses the **workload-resident** slice: the network paths into financially-relevant systems, the flows between them, process context, vulnerability reachability, and change drift.

---

## CSW effectiveness for this framework

- **Operating effectiveness across the period**, rather than a walkthrough sample — Denied Connections provides a continuous record that the access restriction held
- **A defensible scope boundary** — labels and ADM show what actually communicates with the financial reporting core, which frequently corrects the scoping memo

- **The flow of transactions**, machine-generated, as AS 2201 expects the auditor to understand
- **Drift detection** between testing cycles, supporting a benchmarking argument for automated controls

**Compared to manual programmes:** SOX ITGC testing has historically relied on point-in-time samples — a firewall rule screenshot, a quarterly access list. Those show the control *existed* on one date. CSW ties evidence to **live workload behaviour** across the whole period and produces queryable exports on demand, which is what "operated effectively throughout the period" actually requires.

---

## 1. Overview

The Sarbanes-Oxley Act of 2002 was enacted following a series of financial reporting failures. For technology teams, three provisions matter:

| Provision | Requirement | Relevance to CSW |
|---|---|---|
| **Section 302** | Quarterly management certification of disclosure controls | Quarterly evidence cadence |
| **Section 404(a)** | Annual management assessment of internal control over financial reporting (ICFR) | The testing programme CSW feeds |
| **Section 404(b)** | External auditor attestation on ICFR (accelerated filers) | The audience that will challenge the evidence |
| **Section 409** | Rapid disclosure of material changes | Incident reconstruction support |

ICFR is assessed against a recognised framework, in practice **COSO 2013**. The IT portion — **IT general controls** — is where CSW participates, and most organisations structure ITGC against **COBIT 2019**. The external auditor works to **PCAOB AS 2201**, which requires a top-down, risk-based approach: identify significant accounts and disclosures, understand the **flow of transactions**, identify where misstatement could occur, and test the controls that address those risks.

**CSW is an IT general control over logical access at the network layer, plus a monitoring and evidence source.** It is never, by itself, a SOX control. The control is the organisation's restriction of access to financially-relevant systems; CSW implements part of that restriction and produces the artefacts that prove it operated.

## 1.1 ITGC Domains and CSW Relevance (Summary)

The four domains below are conventional industry and audit-firm structure, not official SOX nomenclature. The abbreviations are used throughout this document for brevity.

| ITGC domain | Focus | CSW Role |
|---|---|---|
| **APD** — Access to Programs and Data | Logical access to applications, databases, operating systems, networks | **Strong for the network-path layer.** Restricts and evidences which systems may reach financially-relevant workloads, and which administrative paths exist. Does **not** govern user accounts, entitlements, or authentication |
| **PC** — Program Changes | Authorisation, testing, and approval of changes to in-scope systems | **Detective only.** Surfaces new packages, new listeners, and dependency changes after a change window. Authorisation remains in ITSM |
| **PD** — Program Development | SDLC, acquisition, implementation of new systems | **Out of scope.** CSW observes a system once it runs; it has no role in how it was built |
| **CO** — Computer Operations | Job scheduling, backup, incident management, monitoring | **Moderate.** Evidences batch and interface connectivity, agent and workload availability signals, and provides forensic reconstruction for incidents |

# 2. Pre-Deployment Checklist

Before deploying CSW sensors and connectors, confirm the following:

- ☐ CSW cluster (SaaS or on-premises) is provisioned and reachable from scoped workloads
- ☐ Outbound connectivity from workloads/agents to the CSW cluster (typically TCP 443)
- ☐ Linux, Windows, **AIX, and Solaris** sensor compatibility verified — financial reporting estates are frequently long-lived

- ☐ Cloud provider accounts connected (AWS, Azure, GCP) via CSW cloud connectors where applicable
- ☐ Current SOX scoping memo obtained: significant accounts, in-scope cycles, financially-relevant applications
- ☐ Supporting infrastructure identified for each in-scope application: database, middleware, job scheduler, managed file transfer, identity dependency
- ☐ Fiscal calendar obtained, with month-end, quarter-end, and year-end close windows marked
- ☐ Stakeholders identified: SOX PMO, internal audit, IT compliance, application owners, external audit liaison
- ☐ Change-management approval obtained for agent installation and, separately, for enforcement windows
- ☐ Agreement with internal audit on **which ITGC control objectives CSW evidence will be attached to** (Section 7 as a starting point) — secure this *before* building, so evidence is designed to the test
- ☐ Agreement with internal audit on **IPE integrity requirements** for CSW exports (Section 11.2)

**Timing.** Avoid introducing enforcement during a close window. Align the Phase 3 to Phase 4 transition with a post-close period and document the rationale — auditors view change discipline around close favourably.

---

# 3. Phase 1 — Sensor Deployment (Days 1–5)

## 3.1 On-Premises Workloads

**Install software sensors:**

```
# Linux (RHEL/CentOS/Ubuntu family)
sudo rpm -ivh tet-sensor-<version>.rpm    # RHEL/CentOS family
sudo dpkg -i tet-sensor-<version>.deb    # Debian/Ubuntu family

# Verify the agent service
systemctl status csw-agent || systemctl status tetration-agent
```

**Key sensor configuration (SOX-aligned):**

- Enforcement mode: **Monitoring Only** initially — never introduce blocking on a financially-relevant system before baselining
- Collection: Enable process, network flow, and software inventory where supported; enable vulnerability features to support risk-ranking of in-scope hosts
- Tags: Apply SOX scoping metadata from day one, for example `sox_scope:in-scope`, `sox_cycle:record-to-report`, `financial_app:erp-prod`, `itgc_domain:access`

### 3.2 Cloud Workloads (AWS / Azure / GCP)

**Option A — Software sensor on cloud VMs:** Same installation pattern as on-premises. Preferred for in-scope workloads, because process-level visibility is part of what makes the evidence persuasive.

**Option B — CSW cloud connectors (agentless inventory/flow context):**

```
CSW UI → Platform → External Orchestrators
  → Add AWS / Azure / GCP connector
  → Attach least-privilege IAM role (AWS) or service principal (Azure)
  → Enable flow log or cloud network telemetry ingestion per vendor
guidance
```

> **Document the distinction in your control narrative.** Agentless coverage gives inventory and flow context and enforces through cloud security groups and NSGs. **Process-level visibility comes from the agent.** If an in-scope workload is agentless, say so and state what evidence is therefore unavailable, rather than letting a tester assume parity.

### 3.3 Sensor Validation

```
CSW UI → Manage → Agents
  → Confirm agents are Active and versions are standardized
  → Verify telemetry (flows/process events) visible for each in-scope
application
```

**Reconcile deliberately.** Compare the CSW agent list against the SOX in-scope host list from the scoping memo. Every difference is one of three things: a host that should be in scope and was missed by the memo, a host in the memo that no longer exists, or a coverage gap. The first two are scoping corrections worth raising with the SOX PMO. The third belongs in the deficiency tracker.

---

## 4. Phase 2 — Scope and Inventory Design (Days 6–10)

### 4.1 SOX-Aligned Scope Hierarchy

Design scopes to mirror the financial reporting architecture and the business cycles in your scoping memo, not network topology:

```
Root Scope
└── SOX-Relevant
    ├── Financial-Reporting-Core
    │   ├── ERP-Production            (general ledger, sub-ledgers)
    │   └── Consolidation-and-Close   (EPM, consolidation, statutory
reporting)
    ├── Feeder-Systems
    │   ├── Order-to-Cash             (billing, AR, revenue)
    │   ├── Procure-to-Pay            (AP, procurement)
```

```
│   ├── Payroll-and-HCM
│   └── Treasury-and-Banking
├── Supporting-Infrastructure
│   ├── Database-Tier
│   ├── Batch-and-Scheduling
│   ├── Managed-File-Transfer
│   └── Identity-Dependencies
└── Admin-Access                    (jump hosts, privileged tooling)

└── Non-SOX-Adjacent                (retained deliberately — see
note)
```

> **Keep a Non-SOX-Adjacent scope.** The most valuable segmentation evidence in a SOX audit is not what the in-scope systems talk to — it is proof that out-of-scope systems **cannot reach** the financial reporting core. A deny rule between these two scopes, with a Denied Connections record behind it, is the clearest boundary evidence available.

## 4.2 Label Design

| Label Key | Example Values | SOX / ITGC Tie-In |
|---|---|---|
| `sox_scope` | `in-scope`, `boundary`, `out-of-scope` | Defines and defends the audit boundary |
| `sox_cycle` | `order-to-cash`, `procure-to-pay`, `record-to-report`, `payroll`, `treasury` | Links technical evidence to significant accounts and business cycles |
| `financial_app` | `erp-prod`, `consolidation-prod` | Traceability to the financially-relevant application list |
| `fiscal_relevance` | `transaction-processing`, `key-report`, `supporting` | Risk-ranking for a top-down AS 2201 approach |
| `itgc_domain` | `access`, `change`, `operations` | Reporting filters per control-objective owner |
| `app_owner` | team name | Attribution for walkthrough and signoff |
| `env` | `prod`, `nonprod`, `dr` | Production versus non-production separation evidence |

> **`fiscal_relevance:key-report` earns its keep.** Auditors test the completeness and accuracy of key reports used in financial reporting. Labelling the hosts that generate them lets you produce access and change evidence for exactly those systems on request.

### 4.3 Inventory Filters for In-Scope Platforms

```
Filter: Financial-Database-Tier
  - Process: oracle, sqlservr, db2sysc, postgres, mysqld
  - Ports: 1521, 1433, 50000, 5432, 3306

Filter: Batch-and-Interface
  - Process: cron, at, autosys, control-m agents, sqlldr, informatica
  - Use to confirm close-cycle jobs are captured in the ADM window

Filter: Managed-File-Transfer
  - Process: sftp-server, connect-direct, mftps-style agents (validate
locally)
  - Ports: 22, 1364, vendor-specific
  - Interfaces are where undeclared financial data flows are usually
found

Filter: Admin-Tooling
  - Process: sshd, winrm, RDP-related patterns (validate in your
environment)
  - Use for APD administrative-path review — not identity or MFA
```

---

## 5. Phase 3 — Visibility, Baseline, and ADM (Days 11–45)

### 5.1 The close cycle governs your baseline window

**This is the most important operational point in this reference design.** A financial reporting estate does not look the same mid-month as it does at close. Consolidation jobs, inter-company interfaces, revaluation batches, statutory reporting extracts, and reconciliation tooling may run **once a month or once a quarter**. A two-week ADM window taken mid-month will miss them, and the resulting policy will block the close.

Run ADM across **at least one complete month-end close**, and preferably a **quarter-end**, before authoring policy. Where a year-end-only process exists — statutory consolidation, audit extract jobs — document it as a known exception and either extend the window or hold an explicit allow rule with an owner attached.

```
CSW UI → Investigate → Application Dependency Mapping
  → New Workspace
  → Name: "SOX-FinancialCore-Baseline-ADM"
  → Scope: Financial-Reporting-Core (expand iteratively)
  → Time window: 30–45 days minimum, spanning a full close
  → Start ADM
```

**ADM settings:**

- Enable **process context** on connections — a tester distinguishing an approved interface from an ad-hoc one relies on it
- Enable **user context** where the sensor supports it, for administrative-path analysis

- Retain sufficient history to cover the testing period and the roll-forward to year-end; align with your records retention schedule

## 5.2 Baseline Questions Mapped to ITGC Objectives

| Question during ADM review | Primary ITGC domain | COBIT anchor |
|---|---|---|
| Can any out-of-scope or non-production system reach the financial reporting core? | **APD** | DSS05.02 |
| Are administrative paths into in-scope systems constrained to approved jump hosts? | **APD** | DSS05.05 |
| Which interfaces move financial data in or out, and are they all declared in the scoping memo? | **APD**, **CO** | DSS05.02, DSS01 |
| Do batch and close jobs run from the systems the process documentation claims? | **CO** | DSS01 |
| Did new software versions or listeners appear without a matching change ticket? | **PC** | BAI06, BAI10 |
| Which in-scope hosts carry exploitable vulnerabilities on a reachable path? | **APD** | EDM03 |

## 5.3 Undeclared interfaces are a finding, not a nuisance

Expect ADM to surface flows nobody declared — a reporting tool pulling directly from the general ledger database, a departmental server receiving an extract, a vendor connection into a feeder system. Treat each as a **scoping question for the SOX PMO**, because an undeclared data flow into or out of a financially-relevant system may widen the boundary.

Raise these early. Discovering them during external audit fieldwork is materially worse than discovering them in Phase 2.

## 5.4 Change and Configuration Signals (**PC**)

Use CSW to **detect** technical drift; ITSM remains the system of record for **authorisation**:

```
# Illustrative weekly drift workflow
# 1. CSW UI → Investigate → Inventory → Export CSV (weekly, in-scope
scope only)
# 2. Diff against prior week for: new packages, new listening ports,
new long-lived processes
# 3. Attach diff to the change record, or raise an exception if no
ticket exists
```

An inventory delta with **no corresponding change ticket** is the useful output here. It is a detective control over the change process itself, and it is reportable evidence for the PC domain — but only if the comparison runs on a schedule and the results are retained.

---

# 6. Phase 4 — Policy Design and Enforcement (Days 46–70)

## 6.1 SOX-Oriented Policy Workspace

Translate the access objective into segmentation policy. The target state is that financially-relevant systems accept connections only from declared, approved sources.

**Illustrative absolute policies (tune to your ADM):**

```
DENY: Non-SOX-Adjacent    → Financial-Reporting-Core (all ports)
DENY: Development-Test    → Financial-Reporting-Core (all ports)
DENY: Any-NonJumpHost     → SOX-Relevant (ports 22, 3389, WinRM
ranges)
DENY: Financial-Reporting-Core → Internet (default; explicit egress
exceptions only)
```

**Illustrative allowlist policies:**

```
ALLOW: ERP-Production         → Database-Tier (application ports from
ADM)
ALLOW: Feeder-Systems         → ERP-Production (declared interface
ports only)
ALLOW: Consolidation-and-Close → ERP-Production (close-window
interfaces)
ALLOW: Batch-and-Scheduling   → SOX-Relevant (job-execution paths from
ADM)
ALLOW: Managed-File-Transfer  → Feeder-Systems (declared transfer
ports)
ALLOW: SOX-Relevant           → Identity-Dependencies (LDAPS 636 /
Kerberos as validated)
ALLOW: Monitored-Jump-Host    → SOX-Relevant (admin ports, source-
locked)
ALLOW: Scoped-Workloads       → CSW-Cluster (443 to telemetry
endpoints)
```

**Catch-all instrumentation:**

```
LOG:   unmatched inbound to Financial-Reporting-Core
LOG:   unmatched outbound from Financial-Reporting-Core
ALERT: first-seen external destination from SOX-Relevant
ALERT: any flow from Non-SOX-Adjacent to Financial-Reporting-Core
```

### 6.2 Policy Workspace Setup

```
CSW UI → Defend → Segmentation
  → New Workspace
  → Name: "SOX-FinancialCore-Access"
  → Scope: Financial-Reporting-Core
  → Import ADM-recommended rules → refine with application owners
  → Mode: Simulation → Enforcement (staged)
```

### 6.3 Enforcement Progression

| Stage | Mode | Duration | SOX intent |
|---|---|---|---|
| 1 | Simulation | Spanning a full close | Observe deviation before blocking; produces the change-board evidence |
| 2 | Selective enforcement | 2–4 weeks | Reduce access risk incrementally on lower-risk tiers first |
| 3 | Full enforcement (approved ruleset) | Ongoing | The sustained APD control that testing will sample |

**Document the approval.** Every stage transition should carry a change record, an application-owner acknowledgement, and the simulation report that justified it. That package is itself evidence of change discipline over the control, which the PC domain will ask about.

### 6.4 Rollback is part of the control design

CSW programmes the native host firewall and is not an inline data-path component, so last-applied policy persists if the control plane is unreachable. Enforcement can be withdrawn by workspace. State the rollback path in the control narrative and, ideally, record one controlled rollback test. Change-control and audit functions both respond well to a demonstrated reversal path.

---

## 7. Phase 5 — Control-Objective Mapping

The table maps **conventional ITGC control objectives** to CSW capabilities and representative evidence, with COBIT 2019 cross-references. The objective wording below is illustrative of

common practice; **align it to your own control library and your external auditor's expectations before use.**

| ITGC domain | Control objective (illustrative wording) | CSW capability | Evidence produced | COBIT |
|---|---|---|---|---|
| **APD** | Network access to financially-relevant systems is restricted to authorised sources | Microsegmentation with explicit allow/deny; enforcement on the native host firewall | Enforced policy export; Denied Connections for the period; boundary deny rule between in-scope and out-of-scope scopes | DSS05.02 |
| **APD** | Administrative access paths to in-scope systems are restricted and monitored | Source-locked admin-port policy; visibility into admin tooling paths | Rules restricting 22/3389/WinRM to jump hosts; flow records of paths actually used | DSS05.05 |
| **APD** | Production and non-production environments are segregated | Scope-to-scope deny with enforcement | Policy export plus denied-flow record proving the separation held | DSS05.02 |
| **APD** | The population of in-scope systems is complete and accurate | Inventory, labels, and ADM reconciliation against the scoping memo | Inventory CSV reconciled to the memo; exception list; agent coverage report | BAI10 |
| **APD** | Reachable technical vulnerabilities on in-scope | CVE awareness with reachability | Vulnerability report filtered to `sox_scope:` | EDM03 |

| ITGC domain | Control objective (illustrative wording) | CSW capability | Evidence produced | COBIT |
|---|---|---|---|---|
| | systems are identified and prioritised | and exposure context | `in-scope`; reachability analysis | |
| **PC** | Changes to in-scope systems are identified and reconciled to authorised change records | Software inventory deltas; new listener and process detection; policy versioning | Weekly inventory diff; list of deltas without a matching ticket; ADM diff across a change window | BAI06, BAI10 |
| **PC** | Changes to the access control itself are authorised and traceable | Policy version history; Administratio n audit log | Policy export history with checksums; audit-log extract of who changed policy and when | MEA02 |
| **CO** | Scheduled jobs and interfaces supporting financial reporting execute as documented | Flow and process telemetry on batch, scheduling, and file-transfer tiers | Flow records of close-cycle jobs with process context; interface inventory | DSS01 |
| **CO** | Monitoring is in place to detect events affecting in-scope systems | Alerting on policy violations, first-seen egress, agent loss | Alert history; agent availability report; SIEM forwarding samples | MEA01, DSS01 |
| **CO** | Incidents affecting in-scope systems can be investigated and reconstructed | Forensic flow and process search with parent/child context | Incident-timeline export; filtered flow capture for the event window | DSS02 |

| ITGC domain | Control objective (illustrative wording) | CSW capability | Evidence produced | COBIT |
|---|---|---|---|---|
| **PD** | — | **No CSW contribution.** Program development is out of scope | — | — |

> **Attach, do not substitute.** Where a control objective also requires user entitlement review, approval workflow, or management review, keep CSW evidence **adjacent** under the same objective and make clear in the narrative which portion it supports.

---

# 8. Phase 6 — Vulnerability, Reachability, and Risk Inputs

## 8.1 Vulnerability and Exposure Reporting

```
CSW UI → Investigate → Vulnerability Report
  → Scope: SOX-Relevant
  → Filters: fiscal_relevance, CVSS, EPSS (where available), known
exploit context
  → Export for the SOX PMO and IT risk working papers
```

## 8.2 Prioritisation Pattern

1. **Externally or partner-exposed** in-scope workloads with critical CVEs — patch or segment first
2. **Laterally reachable** financial reporting core systems from lower-trust entry points
3. **Deep internal** in-scope workloads with CVEs but no observed risky path — document the compensating segmentation

## 8.3 How this lands in a SOX conversation

Vulnerability data is not itself an ITGC. Its value is in supporting the **risk assessment** that drives a top-down AS 2201 approach, and in evidencing compensating controls where patching is deferred on a system that cannot easily be taken down during a close period. Frame it that way; presenting a CVE list as a SOX control invites a challenge you will lose.

---

# 9. Phase 7 — Monitoring, Drift, and Period Evidence

## 9.1 Monitoring Patterns

| Monitor | Trigger | ITGC relevance |
|---|---|---|
| Denied flow from out- | Any occurrence | **APD** — boundary |

| Monitor | Trigger | ITGC relevance |
|---|---|---|
| of-scope to financial core | | evidence, and a possible scoping issue |
| Policy violation rate spike | Sudden change in denies | **APD**, **CO** |
| New external destination | First-seen egress from in-scope | **APD** |
| Inventory delta without a change ticket | Weekly diff | **PC** |
| Agent offline on an in-scope host | Loss of visibility | **CO** — and a potential evidence gap for the period |
| Scope drift | Untagged assets communicating with in-scope systems | **APD** |

## 9.2 Agent gaps are period-evidence gaps

Treat an agent that was offline for part of the fiscal period as a **control deficiency candidate**, not merely an operational issue. If the control is "network access is restricted and monitored," a host with no telemetry for six weeks has no evidence for those six weeks. Log the outage window, the affected hosts, and any compensating evidence, and give it to internal audit rather than letting a tester find the hole.

## 9.3 Continuous evidence supports roll-forward and benchmarking

SOX testing is usually performed at an interim date and then rolled forward to year-end. Continuous CSW evidence suits this well: the interim test establishes the control operated, and the policy version history plus Denied Connections for the intervening period support the roll-forward without re-performing the full test.

The same logic applies to **benchmarking** an automated control. Where the automated element has not changed, prior-period testing can be relied upon. A versioned, checksummed policy export demonstrating the ruleset is unchanged since the last test is exactly the artefact that argument needs. **Agree any benchmarking strategy with your external auditor in advance** — it is their judgement to accept, not yours to assert.

## 9.4 Forensic Use

```
CSW UI → Investigate → Flow Search
  → Time range: incident window
  → Source/Destination: affected workload or subnet
  → Export: CSV/JSON with process attributes

CSW UI → Investigate → Process Search
  → Filter: workload + time + suspicious parent chain
  → Export for the incident record
```

Align retention with enterprise records management. CSW exports are **copies** held for audit and legal purposes.

---

## 10. Boundaries — What CSW Does **Not** Cover

Document these explicitly in control narratives to avoid over-claiming SOX coverage:

- **Attestation.** CSW is not an attestation and does not make an organisation SOX compliant. It produces artefacts that management and the external auditor evaluate.
- **User access and entitlement review.** The majority of the APD domain — who holds accounts, what entitlements they carry, whether access was recertified, whether leavers were removed — is IAM, PAM, and application-level. **CSW consumes identity from Active Directory, Entra ID, and Cisco ISE; it is not the identity system.**
- **Authentication and MFA.** Out of scope entirely.
- **Segregation of duties within the financial application.** Whether one person can both create and approve a payment is an application control. CSW enforces network paths and cannot see it.
- **Application-layer authorisation.** Enforcement is **L3/L4**, with connection detail through L5. "Which user may post a journal entry" is beyond reach.
- **Change authorisation workflow.** CSW detects drift; ITSM authorises change. CSW cannot tell you whether a change was approved, only that something changed.
- **Program development and SDLC.** No contribution.
- **Backup, recovery, and job-failure handling.** CSW evidences connectivity for batch tiers; it does not manage, verify, or restore backups.
- **Management review controls and entity-level COSO controls.** Out of scope.
- **Financial reporting logic, reconciliations, and journal entry controls.** Out of scope.
- **A controls library or GRC workflow.** Integrate CSW exports into your GRC tool; CSW does not maintain control narratives, test plans, or deficiency workflow.

---

## 11. Audit Preparation and Evidence Export

### 11.1 Typical Evidence Package (Quarterly, aligned to Section 302)

| Evidence item | CSW source | Suggested frequency | Mapped domain |
|---|---|---|---|
| Enforced segmentation policy export | Defend → Segmentation | Each release + quarterly | **APD** |
| Denied Connections extract for the period | Investigate → Flows / Denied | Quarterly, full period | **APD** — operating effectiveness |
| Boundary proof: | Flow Search, | Quarterly | **APD** |

| Evidence item | CSW source | Suggested frequency | Mapped domain |
|---|---|---|---|
| out-of-scope to in-scope denies | scope-filtered | | |
| Simulation report and enforcement approval | Policy lifecycle records | Per cutover | **PC** |
| ADM baseline snapshot spanning a close | Investigate → ADM | 90 days | **CO**, **APD** |
| Inventory baseline + weekly delta | Investigate → Inventory | Weekly, summarised quarterly | **PC** |
| Deltas without a matching change ticket | Inventory diff + ITSM reconciliation | Monthly | **PC** |
| Agent coverage and availability report | Manage → Agents | Monthly | **CO** |
| Policy change audit log | Administration → Audit Log | Quarterly | **PC**, SoD over the control |
| Vulnerability + reachability summary | Investigate → Vulnerability | Monthly | Risk assessment input |

## 11.2 IPE integrity — treat CSW exports as Information Produced by the Entity

This section is the one most often overlooked, and it decides whether a tester can rely on your evidence or has to re-perform it.

When a CSW export is used as audit evidence, it becomes **IPE**, and the auditor must satisfy themselves it is complete and accurate. An undated CSV with no indication of who produced it, from which scope, over what period, is weak evidence regardless of how good the underlying control is.

For every export retained for SOX purposes, capture:

- **Who** ran it, and under which CSW role
- **When** it was produced, with timezone
- **Parameters**: scope, label filter, and the exact time range
- **The source**: CSW cluster identifier and software version
- **Integrity**: a hash of the file, recorded separately from the file

```
#!/usr/bin/env bash
set -euo pipefail
# Illustrative: archive a quarterly evidence bundle with an IPE cover
```

```
record
DATE=$(date +%F)
EXPORT_DIR="/secure/evidence/csw/sox/${DATE}"
mkdir -p "${EXPORT_DIR}"

# Replace with your approved CSW API/export mechanism:
# curl -sS -H "Authorization: Bearer ${CSW_API_TOKEN}" \
#   "https://<csw-cluster>/api/v1/inventory/export?scope=sox-relevant"
\
#   -o "${EXPORT_DIR}/inventory-sox.csv"

cat > "${EXPORT_DIR}/IPE-COVER.txt" <<EOF
Produced by   : ${USER}
Produced at   : $(date -Is)
CSW cluster   : <cluster-identifier>
CSW version   : <version>
Scope         : SOX-Relevant
Label filter  : sox_scope=in-scope
Period covered: <start> to <end>
Purpose       : SOX ITGC evidence, APD and PC domains
EOF

sha256sum "${EXPORT_DIR}"/* > "${EXPORT_DIR}/MANIFEST.sha256" || true
echo "Bundle prepared at ${EXPORT_DIR}"
```

> **Note:** Use your organisation's approved API tokens, IP allow lists, and secrets management. Never embed live tokens in scripts committed to repositories.

## 11.3 Control Testing Tips

- **Design effectiveness.** Show that in-scope workloads are fully sensor-covered, that the policy expresses the intended restriction, and that enforcement mode matches the narrative.
- **Operating effectiveness.** This is where CSW is strongest. Sample time windows across the period and produce Denied Connections showing the restricted paths remained restricted. A negative test — an attempted connection that was blocked and logged — is the single most persuasive artefact available.
- **Population completeness.** Expect the tester to challenge the in-scope population. Have the inventory-to-memo reconciliation and the exception list ready.
- **Gap handling.** Where a control objective requires entitlement review or change approval, keep CSW evidence adjacent under the same objective but never substitutive.
- **Deficiency framing.** An agent coverage gap, an undocumented interface, or an inventory delta without a ticket are all findings. Surfacing them yourself with a remediation plan is a materially better position than having them discovered in fieldwork.

---

## 12. Common Pitfalls

| Pitfall | Mitigation |
|---|---|
| Asserting CSW "provides SOX compliance" or satisfies an ITGC domain outright | Decompose to control objectives; attach evidence only to the network-path portion of APD and the stated CO and PC items |
| Mapping APD to IAM, entitlement review, or MFA | Keep the narrative precise: CSW enforces **logical network paths** and observes admin tooling. IdP and PAM own identity and entitlements |
| ADM window that misses the close cycle | Baseline across a full month-end, ideally a quarter-end. This is the most common cause of a blocked close after enforcement |
| Introducing enforcement during a close window | Schedule the Phase 3 to Phase 4 transition post-close, and document the rationale |
| Exports with no IPE cover record | Apply Section 11.2 to every retained export, from the first testing cycle onward |
| Agent gaps treated as an IT backlog item | Log them as period-evidence gaps and route to internal audit |
| Undeclared interfaces quietly allowlisted | Raise each as a scoping question to the SOX PMO before writing the allow rule |
| Claiming a benchmarking strategy unilaterally | Agree benchmarking and roll-forward reliance with the external auditor in advance |
| Presenting a CVE list as a SOX control | Position vulnerability data as risk-assessment input and compensating-control support |
| Policy drift undocumented between testing cycles | Version policy exports with checksums and store alongside change tickets |

## Appendix A — SOX, COSO, and COBIT Orientation

SOX requires an ICFR assessment; **COSO 2013** is the framework almost universally used for it; **COBIT 2019** is the usual structure for the IT general controls beneath it. CSW evidence generated for connectivity security and monitoring feeds the COBIT layer, which in turn supports the COSO control activities component.

Practically, this means **CSW evidence built for COBIT is the same evidence a SOX tester wants.** Maintain a single evidence repository keyed by control objective, so one export serves the COBIT assessment, the SOX ITGC test, and any SOC 2 or ISO engagement running in parallel. Duplicating the work per framework is the most common source of wasted compliance effort.

---

## Appendix B — Related Frameworks

- COBIT 2019 — the ITGC structure most SOX programmes map through; the direct companion to this document.
- SOC 2 Type II — operating-effectiveness-over-a-period evidence, the same testing model as SOX.
- NIST SP 800-53 Rev 5 — detailed control language where a SOX programme needs more specific wording for AC-4 and SC-7.
- ISO/IEC 27001:2022 — frequently runs in parallel at public companies; shares the segmentation evidence.
- NY DFS 23 NYCRR Part 500 — overlapping scope at financial-services filers.

---

*Document prepared for Cisco customer engagements. SOX has no official control catalogue; the ITGC domains and control-objective wording here are conventional industry structure and must be aligned to your own control library, your SOX PMO, and your external auditor before external sharing. Replace bracketed placeholders and tailor scopes to your assessment boundary.*